

Password, Account Lockout, and MFA Runbook

Purpose: restore access through approved identity-recovery paths while protecting the employee account. Support staff must never request a current/new password, MFA code, recovery code, or authenticator export.

Identify the condition

- Forgotten password: the employee cannot recall the current credential.
- Expired password: sign-in explicitly requires a change.
- Account lockout: the identity service reports too many attempts or locked account.
- Password works on web but not an application: likely cached credentials, synchronization delay, or application identity state.
- MFA failure: password is accepted but the second factor is unavailable, delayed, or rejected.
- Suspicious activity: unexpected prompts, unfamiliar recovery details, or a change the employee did not initiate.

Safe starting checks

- Use only the approved company portal or the reset link reached from the normal organizational sign-in page.
- Inspect the domain before entering an identifier. Do not use reset links from unexpected email, SMS, or chat.
- Confirm date, time, keyboard layout, Caps Lock, and network connectivity.
- Stop repeated attempts when lockout is possible.

Self-Service Password Reset and Expiry

Forgotten password

- Open the approved self-service password reset experience from a known company bookmark or normal sign-in page.
- Enter only the identity information requested by that trusted service and complete registered verification.
- Create a unique password that meets the rules displayed by the identity service. Do not reuse a personal password.
- Sign in to the identity portal once to verify the new password before updating applications.

Expired password or required change

- Follow the change-password prompt on a managed device or approved identity portal.
- If connected remotely and the change succeeds, reconnect VPN using the new password.
- Lock and unlock the managed device, or sign out and in, to verify the updated credential where company policy permits.
- Allow a short synchronization period before concluding that a downstream application is broken.

Password changed but an application keeps prompting

- Fully close the application and reopen it. Sign out only if unsynchronized work is safe.
- Check phones, mail clients, VPN clients, mapped drives, scheduled tasks, and older devices that may repeatedly submit the old credential.
- Update or remove the saved credential using the operating system's approved credential manager; do not use third-party password cleanup tools.
- If web sign-in succeeds but one service rejects the new password, record that distinction for IT.

Account Lockout, MFA, and Recovery

Account locked

- Stop retrying. Additional failures can renew the lockout window.
- Check whether another device or application is still using an old password.
- Use approved self-service unlock if offered. Do not claim an unlock succeeded until a normal sign-in is verified.
- Contact IT if the lockout returns quickly; this can indicate stale credentials or malicious attempts.

MFA notification or code problems

- Approve only a prompt initiated by the employee at that moment.
- Confirm the authenticator device has connectivity, notifications are enabled, and automatic date/time is correct.
- If number matching is displayed, enter only the number shown by the trusted sign-in flow.
- For SMS/voice delays, wait briefly and request one new code. Repeated requests can invalidate earlier codes.
- If a phone is lost, replaced, wiped, or inaccessible, use an approved alternate method or contact IT for verified recovery.

Suspicious prompts or account changes

- Deny unexpected MFA requests and report them immediately through an approved channel.
- Change the password through the trusted portal if instructed by security, then sign out active sessions where the organization provides that option.
- Do not delete evidence. Record times, approximate prompt count, application, and location shown.
- IT/security should verify recent sign-ins and recovery methods; the employee should not investigate through untrusted links.

Password Resolution and Escalation

Resolution checks

- The employee can sign in to the approved identity portal with the new/current password.
- Expected MFA completes exactly once and no unexpected prompts remain.
- VPN, mail, and the originally affected application accept the updated identity.
- No old device continues triggering lockouts.

Contact IT immediately

- Unexpected MFA prompts, unauthorized password/recovery changes, suspected phishing, or a lost authenticator device.
- The account is disabled, repeatedly locks, or lacks an approved recovery method.
- Identity verification cannot be completed or recovery details are incorrect.
- A privileged or high-impact account is affected.

Standard ticket evidence

- Username or employee identifier allowed by policy, contact method, device name, and time zone.
- Exact non-secret error, timestamp, affected applications, and last known successful sign-in.
- Whether identity-portal sign-in works, whether a password change was recent, and whether other devices are active.
- Safe steps attempted and sanitized screenshots.

Never put a password, MFA code, recovery code, access token, or authenticator QR code in a ticket.